

OpenBOX

Identificação institucional

Instituição	UnICEUB
Curso	Ciência da Computação
Disciplina	Introdução à Computação
Autor	Alcides Olivo Pollazzon Soterio
Docente/Tutor	Fabício Ofugi

O presente documento consolida o deliverable técnico do workspace **IC01-aops**. Seu objeto não é tratar o **MXQ Pro 4K** como caso ordinário de consumo, mas analisá-lo como artefato de risco. O texto organiza linha do tempo, evidências locais, panorama oficial brasileiro e a composição final em **3 pilares**: **ADV7ia**, **Obsidian meta-vault** e **ADV7Sec (IPS_IDS)**, com base no relatório local importado **[LOC-01]** e no research do retarget **[LOC-02]**.

Nota metodológica. Não foi encontrada fonte governamental brasileira com contagem oficial específica de consumidores do modelo *MXQ Pro 4K*. O documento usa panorama oficial de TV boxes/IPTV pirata no Brasil e contextualização técnica externa para esse modelo **[BR-01]** **[BR-05]** **[BR-07]**.

Predecessor histórico: `OpenBox0.1v/ADV7Box`

Data de consolidação: 2026-04-26

Fonte canônica: OpenBOX.md

Resumo executivo

OpenB0X organiza, em um único artefato, três dimensões complementares: memória operacional, rastreabilidade documental e visibilidade defensiva. Nesse arranjo, o legado **OpenBox / ADV7Box** funciona como antecedente metodológico, enquanto o caso **MXQ Pro 4K** cumpre papel analítico preciso ao representar uma classe de risco de cadeia de suprimento e de mercado [LOC-03] [LOC-04].

1. Método e limites do conjunto probatório

Este artefato adota critério probatório conservador. Não encontrei, em fonte governamental brasileira, uma contagem oficial específica de consumidores do modelo **MXQ Pro 4K**. Por isso, o documento separa a análise em três camadas complementares: fontes oficiais brasileiras para dimensionar mercado e risco regulatório; fontes técnicas externas para descrever campanhas, famílias de malware e vetores de comprometimento; e artefatos locais do workspace para contextualizar o caso sem extrapolar além da evidência disponível [BR-01] [BR-05] [BR-07] [INT-01] [INT-02] [INT-04] [LOC-01] [LOC-02].

Esse recorte evita inventar estatística por modelo onde ela não foi publicada e também evita afirmar, sem imagem forense do aparelho, que toda unidade **RK3229** chega infectada. O documento sustenta algo mais preciso: o **MXQ Pro 4K** pertence a uma classe de dispositivos com histórico documentado de firmware adulterado, malware de cadeia de suprimento e exposição massiva no Brasil [BR-01] [BR-05] [BR-07] [INT-01] [LOC-02].

1.1 Critérios de seleção das fontes governamentais brasileiras

A seleção das fontes governamentais brasileiras foi organizada em uma subseção própria para separar referência institucional, uso probatório e limite interpretativo. O objetivo não é produzir uma estatística por modelo, mas construir um panorama oficial confiável para enquadrar o **MXQ Pro 4K** como exemplar de uma classe de risco.

Critério	Aplicação no documento	Limite metodológico
Origem institucional primária	Priorizar páginas e comunicados em domínios oficiais do Governo Federal, especialmente Receita Federal, Anatel e Ministério das Comunicações.	Não usar republicações, matérias sem órgão emissor claro ou resumos sem rastreabilidade.
Pertinência temática	Selecionar fontes que tratem diretamente de TV boxes piratas, homologação, malware, retirada de mercado, BadBox 2.0 ou IPTV clandestina.	Não transferir automaticamente dados gerais do mercado pirata para o modelo MXQ Pro 4K .
Valor probatório	Usar números oficiais para dimensionar fiscalização, exposição residencial, contaminação conhecida e base usuária.	Não inferir que uma unidade específica esteja infectada sem imagem forense, hash de firmware ou laudo técnico.
Rastreabilidade temporal	Preservar órgão, data e evento para sustentar a linha do tempo externa de risco.	Não misturar eventos regulatórios com evidências locais do workspace sem explicitar a camada de análise.
Separação de métricas	Manter apreensão, retirada de mercado, lares expostos, dispositivos infectados e usuários estimados em eixos distintos.	Evitar gráficos ou leituras que comparem categorias heterogêneas como se fossem a mesma métrica.

Com esse método, as fontes **[BR-01]** a **[BR-07]** são tratadas como base oficial para caracterizar o ambiente brasileiro de risco, não como prova individual contra uma unidade específica do aparelho. A conclusão operacional permanece conservadora: o **MXQ Pro 4K** deve ser analisado como dispositivo potencialmente comprometido até que haja wipe completo, substituição de firmware e verificação pós-flash com evidência técnica própria.

2. Timeline completa

A linha do tempo a seguir separa os marcos internos do projeto e os eventos externos que sustentam a leitura de risco do caso. A divisão evita confundir evolução do artefato acadêmico com fatos regulatórios, policiais e técnicos do ecossistema de TV boxes não homologados.

2.1 Linha do tempo interna do projeto

Data	Marco	Evidência local
2026-04-18	Entrega-base AV01_OpenBox_Audit_Report	OpenBox0.1v/deliverables/AV01_OpenBox_Audit_Report.ms e .pdf
2026-04-23	Consolidação do ADV7Sec com auditoria e tuning	IPS_IDS/ADV7Sec_1.0_AUDIT.md e IPS_IDS/PHASE2_TUNING.md
2026-04-24	Evidência estável do ADV7ia	ADV7ia/evidence/*.log
2026-04-25	Retarget do OpenBox para RK3229 / R29_5G_LP3	OpenBox0.1v/CHANGELOG.md e OpenB0X/sources/rk3229_threat_research.md
2026-04-26	Consolidação do OpenB0X com integração do legado ADV7Box	OpenBox0.1v/ADV7Box/ADV7Box.pdf e este artefato

2.2 Linha do tempo externa de risco

Data	Marco	Leitura para o caso
2021-05-06	Receita destrói mais de 97 mil TV boxes piratas	Mostra o volume histórico do problema no Brasil [BR-01].
2021-12-22	Anatel confirma malware em TV boxes não homologados	O risco é de segurança, não só de pirataria [BR-02].
2022-12-22	Anatel constata novas vulnerabilidades	O problema evolui, não desaparece [BR-03].
2023-03-15	Anatel publica página de TV boxes homologados	Há referência regulatória para o consumidor [BR-04].
2023-09-06	Doctor Web descreve Android.Pandora	Explica persistência e abuso em TV boxes Android [INT-04].
2025-06-05	FBI publica PSA I-060525-PSA	Conecta o ecossistema ao BADBOX 2.0 [INT-01].
2025-08-12	Anatel alerta sobre BadBox 2.0	O Brasil aparece como país fortemente afetado [BR-05].
2025-11-04/05		Escala sistêmica do problema [BR-06].

Data	Marco	Leitura para o caso
	Anatel e MCom consolidam White Paper e balanço de 8 milhões	
2026-01-15	MCom estima 4-6 milhões de usuários recorrentes e 7-8 milhões com eventuais	Dimensiona o mercado pirata [BR-07].

3. Infográfico dos 3 pilares

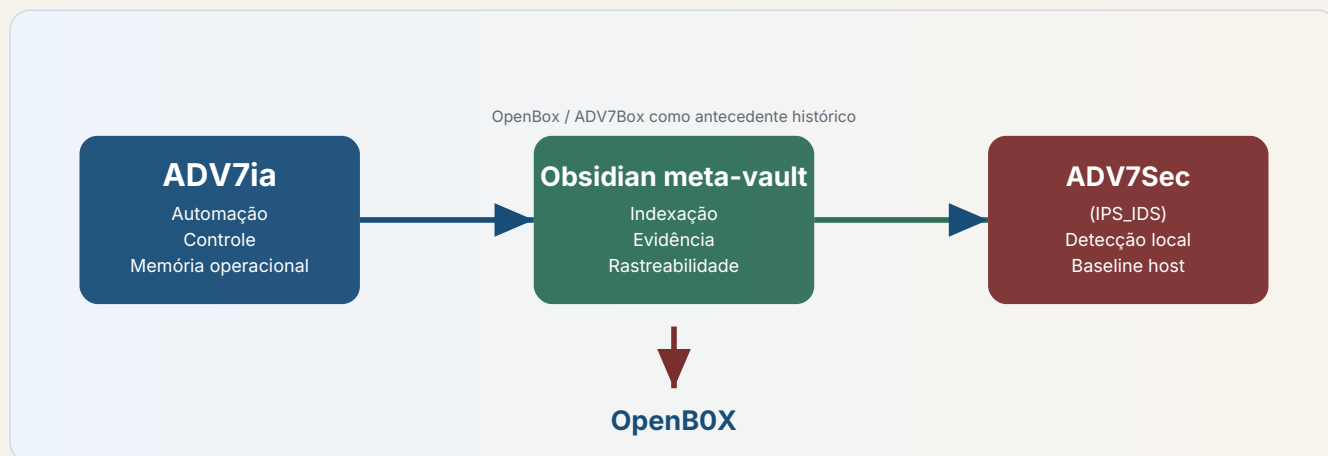


Figura 1. Os 3 pilares finais formam o núcleo técnico do OpenBOX.

O desenho acima separa função e memória: o **ADV7ia** administra controle e evidência, o **meta-vault** organiza rastreabilidade, e o **ADV7Sec** mantém a postura de detecção local. O **OpenBox** aparece como antecessor e referência de método.

4. Estudo de caso de segurança

4.1 Panorama brasileiro

Os dados oficiais brasileiros não sustentam contagem por modelo **MXQ Pro 4K**; contudo, sustentam, com consistência suficiente, o pano de fundo regulatório e operacional necessário para enquadrar o caso. Em particular, o conjunto de fontes mostra destruição de equipamentos piratas, confirmação de malware em TV boxes não homologados, persistência de vulnerabilidades, alerta de BadBox 2.0 e dimensionamento do mercado pirata em milhões de usuários **[BR-01]** **[BR-02]** **[BR-03]** **[BR-05]** **[BR-07]**.

- a Receita Federal destruiu mais de 97 mil aparelhos em 2021 e a ABTA estimou 4,5 milhões de lares expostos **[BR-01]**;
- a Anatel confirmou malware em TV boxes não homologados em 2021 **[BR-02]**;
- em 2022, a Anatel confirmou novas vulnerabilidades e citou 3,8 milhões de produtos retirados do mercado em dois anos **[BR-03]**;
- em 2025, a Anatel afirmou que o Brasil concentrava 1,8 milhão de dispositivos infectados por BadBox 2.0 **[BR-05]**;

- em 2026, o MCom estimou entre 4 e 6 milhões de usuários recorrentes, chegando a 7-8 milhões quando se somam usos eventuais e compartilhamento [BR-07].

Em termos metodológicos, esses dados não autorizam inferência estatística por modelo; autorizam, porém, tratar o **MXQ Pro 4K** como exemplar técnico de uma classe mais ampla de risco.

4.2 MXQ Pro 4K e vulnerabilidades correlatas

O relatório Claude local em `OpenB0X/sources/compass_mxq_pro_5g.md` e o research em `OpenB0X/sources/rk3229_threat_research.md` convergem em quatro pontos: o aparelho é uma variante genérica da família Rockchip RK3229 / RK3228A; o firmware pode carregar backdoor de cadeia de suprimento; o ecossistema Android TV box foi associado a *Android.Pandora* e *BADBOX 2.0*; e o risco real é exfiltração, proxy residencial e pivô lateral na rede [LOC-01] [LOC-02] [INT-01] [INT-02] [INT-04].

4.3 Análise aprofundada do vetor de backdoor no ecossistema RK3229

No caso RK3229, o termo "backdoor" descreve dois planos distintos de risco, que não devem ser confundidos: o plano físico, vinculado ao Maskrom embutido na BootROM do SoC, e o plano lógico, associado ao firmware de cadeia de suprimento e ao carregamento de componentes maliciosos no primeiro boot [INT-01] [LOC-02].

Camada	O que a evidência sustenta	Leitura de risco
Física (BootROM / Maskrom)	o RK3229 mantém modo de recuperação em silício, anterior ao sistema operacional, que permite regravação com acesso físico [LOC-02]	não prova infecção prévia, mas reduz a barreira para adulteração pós-posse
Firmware / cadeia de suprimento	o dispositivo pode sair de fábrica com payload pré-instalado ou baixar componente malicioso no primeiro boot [INT-01] [LOC-02]	explica persistência fora do fluxo normal de uso e a limitação de um simples "factory reset"
Aplicação / ecossistema	sideloading e lojas paralelas reforçam a infecção em boxes piratas [INT-01] [INT-02]	amplia a superfície de comprometimento mesmo sem ataque dirigido

Em outras palavras, o problema central não é um "exploit manual" acionado pelo usuário, mas um modelo de comprometimento embutido na cadeia de fornecimento e reforçado por um hardware que facilita regravação quando há acesso físico. Essa distinção é relevante: Maskrom é uma interface de recuperação em silício, não uma prova de malware; ainda assim, combinado com firmware opaco e boxes genéricas, amplia o risco operacional do aparelho [LOC-02].

4.4 Leitura do material público do FBI

O PSA I-060525-PSA, publicado pelo FBI, não nomeia o RK3229 nem o MXQ Pro 4K individualmente. Ainda assim, é central para este estudo porque descreve, com clareza, o padrão de comprometimento observado na classe de dispositivos em que o aparelho se insere: comprometimento pré-venda, ativação no primeiro boot e monetização do dispositivo para atividade criminosa em background [INT-01].

- confirma o vetor de cadeia de suprimento como risco primário, e não acessório [INT-01];

- reforça que parte do comprometimento pode ocorrer antes de qualquer ação do usuário [INT-01];
- não prova, por si só, que esta unidade específica estava infectada antes da aquisição, o que preserva o rigor metodológico do estudo [INT-01] [LOC-02].

Portanto, a evidência do FBI deve ser utilizada aqui como suporte de classe, e não como laudo pericial de unidade. A conclusão operacional permanece a mesma: tratar o MXQ Pro 4K como potencialmente comprometido até o wipe completo, a troca de firmware e a verificação pós-flash [INT-01] [LOC-02].

4.5 Correlação entre risco, firmware e rede

Eixo	O que o caso mostra	Impacto prático
Firmware	atualização e boot podem carregar código malicioso	o dispositivo não deve entrar na rede antes de wipe completo
Rede	o aparelho pode atuar como proxy residencial ou pivot	o tráfego precisa de isolamento por VLAN ou rede segregada
Usuário	a infecção não é perceptível em uso normal	a defesa precisa ser preventiva, não reativa
Mercado	o problema é massivo no Brasil	o caso individual representa uma classe de exposição

4.6 Desagregação analítica do panorama brasileiro

Em substituição ao gráfico único, este documento passa a organizar os indicadores em três eixos temáticos. A mudança é metodologicamente necessária: apreensões, lares expostos, dispositivos infectados e estimativas de uso pertencem a categorias distintas e, quando exibidos em um único eixo, induzem comparação inadequada.

4.6.1 Fiscalização e retirada de mercado

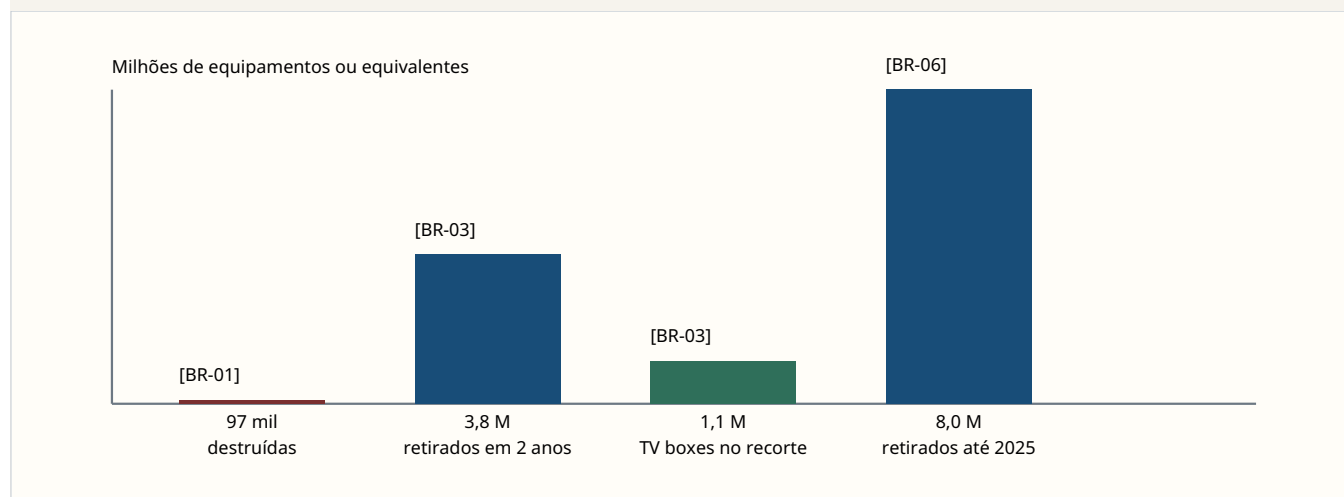


Figura 2. Eixo de fiscalização e retirada de mercado.

O primeiro eixo mede capacidade de repressão, apreensão e retirada de mercado. Ele não informa, por si só, quantos consumidores efetivamente utilizam cada modelo, mas quantifica a escala da resposta estatal ao problema.

4.6.2 Exposição residencial e contaminação

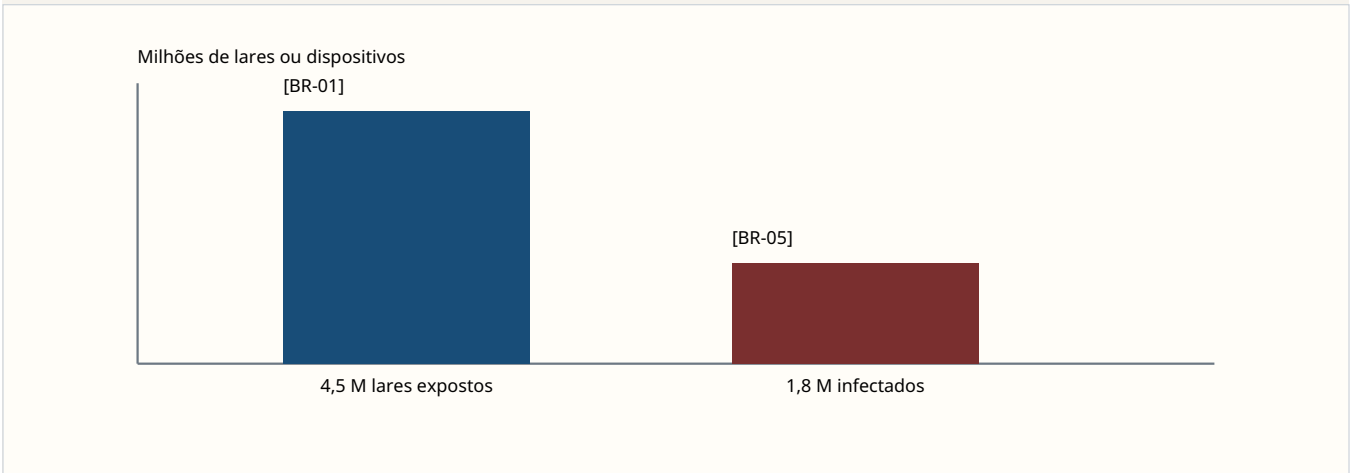


Figura 3. Eixo de exposição residencial e contaminação conhecida.

O segundo eixo aproxima exposição doméstica e contaminação conhecida. Embora as métricas não sejam equivalentes, sua leitura conjunta é útil para demonstrar que o problema não é residual nem circunscrito a apreensões pontuais.

4.6.3 Estimativa de base usuária

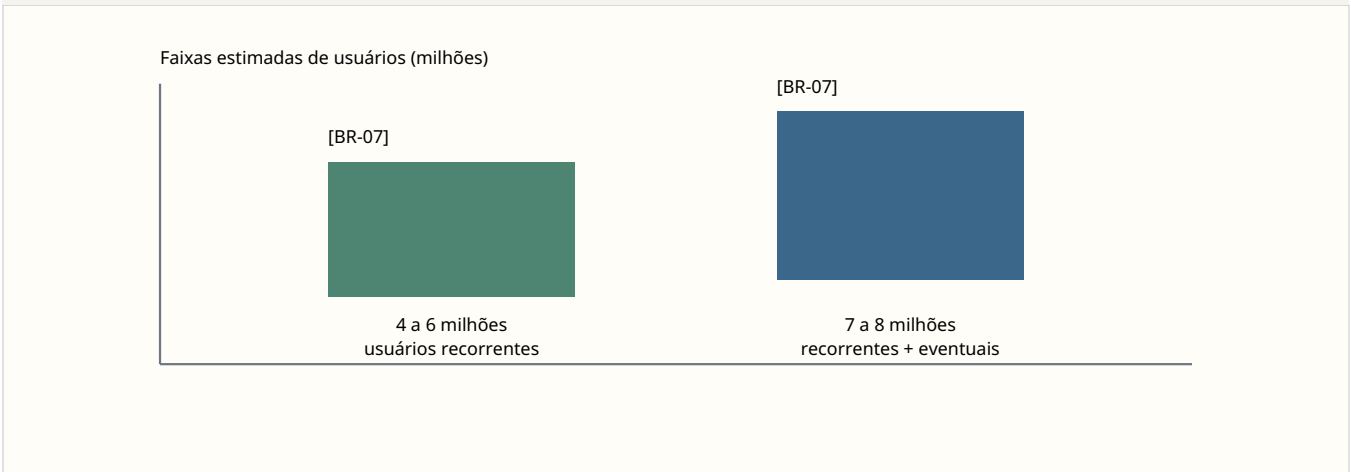


Figura 4. Eixo de estimativa da base usuária de IPTV pirata.

O terceiro eixo desloca a análise do mercado físico para a base usuária. Trata-se da camada mais próxima do impacto social do fenômeno, ainda que continue sem granularidade por modelo.

5. Logs, reports e tests

O material abaixo mostra que o deliverable não foi escrito no vazio. Ele se apoia em logs, validações, auditorias e testes já existentes no workspace.

Bloco	Artefatos	O que prova
OpenBox	OpenBox0.1v/deliverables/AV01_OpenBox_Audit_Report.* , tests/validate-stack.sh , tests/ci-syntax-check.sh	Auditoria técnica, validação da pilha e consistência do repo.

Bloco	Artefatos	O que prova
IPS_IDS / ADV7Sec	ADV7Sec_1.0_AUDIT.md , PHASE2_TUNING.md , tests/test_adv7sec_*.py	Auditoria, tuning e cobertura do runtime de detecção.
ADV7ia	evidence/*.log , tests/validate-*.sh , tools/control-mesh	Memória operacional, trilhas estáveis e controle do mesh local.

6. Referências

[BR-01] Receita Federal, 06/05/2021, [Receita Federal e ABTA destroem mais de 97 mil aparelhos de TV box piratas.](#)

[BR-02] Anatel, 22/12/2021, [presença de malware em aparelhos de TV box não homologados.](#)

[BR-03] Anatel, 22/12/2022, [novas vulnerabilidades em TV box não homologados.](#)

[BR-04] Anatel, 15/03/2023, [TV boxes homologados.](#)

[BR-05] Anatel, 12/08/2025, [BadBox 2.0 em TV boxes piratas.](#)

[BR-06] Anatel / MCom, 04/11/2025 e 05/11/2025, [White Paper](#) e [balanço de 8 milhões.](#)

[BR-07] Ministério das Comunicações, 15/01/2026, [4-6 milhões recorrentes e 7-8 milhões com eventuais.](#)

[INT-01] FBI, 05/06/2025, [Home Internet Connected Devices Facilitate Criminal Activity.](#)

[INT-02] HUMAN Security, 05/03/2025, [BADBOX 2.0.](#)

[INT-03] Google, [ação legal contra o BadBox 2.0.](#)

[INT-04] Doctor Web, 06/09/2023, [Android.Pandora em TV boxes Android.](#)

[LOC-01] OpenB0X/sources/compass_mxq_pro_5g.md

[LOC-02] OpenB0X/sources/rk3229_threat_research.md

[LOC-03] OpenBox0.1v/CHANGELOG.md

[LOC-04] OpenBox0.1v/ADV7Box/ADV7Box.pdf

[LOC-05] ADV7ia/evidence/*.log

[LOC-06] IPS_IDS/ADV7Sec_1.0_AUDIT.md

[LOC-07] IPS_IDS/PHASE2_TUNING.md

7. Conclusão

Em síntese, OpenB0X organiza, em um único artefato, três dimensões complementares: memória operacional (**ADV7ia**), rastreabilidade documental (**Obsidian meta-vault**) e visibilidade defensiva (**ADV7Sec**). O caso **MXQ Pro 4K**, por sua vez, cumpre função analítica precisa: não serve como curiosidade de mercado, mas como exemplo tecnicamente defensável de risco de cadeia de suprimento, opacidade de firmware e exposição ampliada no contexto brasileiro.